



Name: _____ Cohort/Batch: _____ Date: _____ Score: _____

SNYK PRACTICE SHEET - 10 CONCEPTUAL Q&A

10 conceptual Q&A Security

TOTAL: 10 QUESTIONS

Q1 What is Snyk and what security threat does it address? Treat Model

Q6 How do you audit and monitor Snyk events? Observability

Q2 What is the core mechanism Snyk uses to provide security? Security

Q7 How does Snyk handle key or credential rotation? Lifecycle

Q3 How do you configure Snyk for a production web application? Application

Q8 How does Snyk help meet compliance requirements? Compliance

Q4 What are the most common Snyk misconfigurations to avoid? Avoiding

Q9 How do you test your Snyk configuration for weaknesses? Testing

Q5 How does Snyk integrate with identity providers? SSO / IdP

Q10 What are the performance implications of Snyk and how do you minimize them? Downing



ANSWER KEY & EXPLANATORY SOLUTIONS

Comprehensive verified answers, best-practice configs, security controls & reference

VERIFIED SOLUTIONS

A1 Snyk is a security tool, protocol, or

Mitigation

Snyk is a security tool, protocol, or service that mitigates a specific class of threats authentication bypass, data exfiltration, network intrusion, or credential theft. Understanding the threat model is prerequisite to correct configuration.

A6 Enable Snyk's audit log and stream it

Observability

Enable Snyk's audit log and stream it to a SIEM (Splunk, Elastic SIEM). Define alert rules for high-severity events: repeated failed logins, privilege escalation, and unusual access patterns. Review logs regularly.

A2 Snyk uses one or more security primitives:

Primitives

Snyk uses one or more security primitives: asymmetric cryptography, symmetric encryption, certificate chains, role-based access control, or anomaly detection. These primitives are combined to provide the claimed security properties.

A7 Automate rotation using a secrets manager that

Automation

Automate rotation using a secrets manager that generates new credentials and updates consumers transparently. Test rotation in staging. Have a break-glass procedure for emergency rotation when a credential is compromised.

A3 Production configuration requires strong cipher suites

Hardening

Production configuration requires strong cipher suites, certificate rotation, revocation checking, and minimal permission grants. Use a well-reviewed configuration reference (CIS Benchmark, OWASP) rather than default settings.

A8 Snyk generates audit trails, enforces access policies,

Governance

Snyk generates audit trails, enforces access policies, and provides encryption that satisfy controls required by SOC 2, PCI-DSS, HIPAA, and GDPR. Map Snyk's capabilities to the specific framework controls in your compliance program.

A4 Common mistakes include using outdated algorithms (MD5)

MD5 has

Common mistakes include using outdated algorithms (MD5, SHA1, RC4), leaving default credentials, ignoring certificate expiry, granting excessive permissions, and not testing the config before going live in production.

A9 Run an automated scanner (SSL Labs for

Assessment

Run an automated scanner (SSL Labs for TLS, ScoutSuite for cloud IAM, OWASP ZAP for web app auth) against your Snyk config. Conduct penetration tests annually and after significant config changes.

A5 Snyk delegates identity verification to an IdP

Federation

Snyk delegates identity verification to an IdP via SAML, OIDC, or LDAP. Users authenticate once (SSO) and receive a token that Snyk validates. This centralizes user management and avoids duplicating auth logic across services.

A10 Cryptographic operations, token validation, and authorization

Authorization

Cryptographic operations, token validation, and authorization checks add latency. Mitigate with session caching, hardware-accelerated TLS (AES-NI), connection reuse, and async authorization where possible.